Ders 3 Çalışma Özeti

Ders 3 Çalışma Özeti

Genel Konular

- Kontrol ve verinin karışması
  - Buffer overflow, heap spraying, use after free, integer overflow ve format string saldırılarının temelinde veri ile kontrol bilgisinin aynı alanda veya aynı kanalda yorumlanması problemi bulunur.
  - Return address gibi kontrol verilerinin kullanıcı girdisiyle değiştirilebilir alanda tutulması kritik risk doğurur.
- In-band ve out-of-band kontrol
  - Uygulama verisiyle kontrol bilgisinin aynı kanaldan taşınması in-band kontrol olarak açıklanır.
  - Kontrol bilgisinin ayrı kanaldan taşınması out-of-band yaklaşımdır ve bazı saldırı sınıflarını azaltabilir.
- Captain Crunch analojisi
  - Telefon sistemlerinde ödeme bilgisinin konuşma hattıyla aynı kanaldan sinyallenmesi, sahte sinyalle sistemin kandırılmasına yol açmıştır.
  - Bu örnek, kontrol verisi ile kullanıcıya açık veri kanalının karışmasının bilgisayar güvenliğindeki karşılığına benzetilir.
- Savunma yaklaşımları
  - Hataları bulma ve düzeltme, type-safe diller kullanma, platform seviyesinde savunma ve uygulamaya runtime kontrol ekleme ana yaklaşımlar olarak ele alınır.
  - Savunmalar çoğu zaman tam ele geçirmeyi engeller; ancak saldırıyı hizmet kesintisine dönüştürebilir.
- Platform savunmaları
  - Kod enjekte edilen girdinin çalıştırılmasını engellemek, bellek bölgelerini çalıştırılamaz yapmak ve adres tahminini zorlaştırmak platform düzeyinde savunmanın temel mantığıdır.

Hocanın Özellikle Vurguladığı Kısımlar

- Asıl tasarım hatası data ve control bilgisini karıştırmaktır
  - Güvenli tasarımda kullanıcı verisi ile kontrol verisi mümkün olduğunca ayrılmalıdır.
- In-band kontrol kolaydır ama risklidir
  - Aynı kanalın hem veri hem kontrol amacıyla kullanılması pratik görünse de saldırganın kontrol bilgisini taklit etmesine yol açabilir.
- Savunmalar mutlak güvenlik sağlamaz
  - Çoğu savunma tam ele geçirmeyi engelleyip programın çökmesine neden olur; bu yine de daha kabul edilebilir bir sonuçtur.
- Type-safe dil tek başına yeterli değildir
  - Çalışma zamanı ortamı veya sistem kütüphaneleri C/C++ ile yazılmışsa zafiyet devam edebilir.

Kısa Tekrar Notları

- Data-control karışımı birçok saldırının ortak kök nedenidir.
- In-band signalling kontrol bilgisini veri kanalıyla taşır.
- Out-of-band signalling kontrolü ayrı kanala alır.

- Savunma stratejileri: audit, güvenli dil, platform koruması, runtime kontrol.
- Tam ele geçirme yerine DoS oluşması çoğu savunmanın beklenen sonucudur.

Detaylı Açıklamalar

- Stack smashing saldırısında return address, yerel değişkenlere komşu bir alanda bulunduğu için taşan veri tarafından değiştirilebilir. Bu, kullanıcı verisinin kontrol bilgisini ezmesidir. Use after free örneğinde ise serbest bırakılmış nesne alanının saldırgan tarafından vtable biçimine uygun veriyle doldurulması benzer şekilde kontrol akışını etkiler.
- In-band kontrol, mevcut iletişim kanalını yeniden kullanarak sistem tasarımını basitleştirir. Ancak kanal kullanıcı tarafından etkilenebiliyorsa saldırgan kontrol sinyalini taklit edebilir. Captain Crunch örneği, bilgisayar dışı bir sistemde aynı tasarım hatasının nasıl istismar edildiğini gösterir.
- Savunma üretirken yalnızca zafiyeti kapatmak değil, zafiyetin neden oluştuğunu anlamak gerekir. Mevcut kodu tamamen yeniden yazmak çoğu durumda maliyetlidir; bu nedenle platform seviyesinde DEP/NX, ASLR benzeri mekanizmalar veya uygulama içine eklenen runtime kontroller pratik hale gelir.
- Güvenlik tedbirlerinin önemli bir bölümü saldırganın kod çalıştırmasını engeller; ancak yanlış girdi geldiğinde programı durdurabilir. Bu durum hizmet kesintisi anlamına gelse de sistemin tamamen ele geçirilmesinden daha düşük risklidir.
- **Not:** İsterseniz bu dersin altyazı (.srt) dosyasını Gemini Notebook gibi bir yapay zeka aracına yükleyerek ders hakkında daha detaylı soru-cevaplar yapabilir ve dersi verimli çalışabilirsiniz.